

Authorized Security Lab Dossier

Student: Danda Nirupa | ID: RAB-2026-5A2B06A17D | Date: September 2026

1. Rules of Engagement & Authorization

- Written Authorization:** This document formally authorizes Danda Nirupa (Assessor) to conduct security testing against the isolated laboratory environment owned by the Assessor for educational purposes. No external systems may be targeted. Authorization Date: September 18, 2026.
- Permitted Techniques:** Reconnaissance (port scanning, service enumeration), Vulnerability validation (manual testing, SQLi, XSS), and authorized reporting activities. Tools permitted include Nmap, Wireshark, Burp Suite, and OWASP ZAP.
- Explicit Exclusions:** Denial of Service (DoS/DDoS) attacks are strictly prohibited. No destructive payloads, persistence mechanisms, or credential reuse across personal accounts are allowed. Testing of third-party platforms (e.g., cloud providers) is excluded.
- Testing Window & Stop Conditions:** Testing is limited to the defined local lab runtime. Stop conditions include unexpected system crashes, discovery of out-of-scope assets, or hardware failure.
- Evidence Handling:** Only minimum required evidence (screenshots, scan logs) will be retained. All personal or sensitive data encountered must be redacted. All logs will be purged 30 days post-assessment.

2. Asset Inventory & Boundaries

Asset ID	Hostname / IP	Role / Service	Data Classification	In Scope?
SRV-01	192.168.56.101	Web Application (Juice Shop)	Mock PII / Credentials	Yes
SRV-02	192.168.56.102	Database Backend (SQLite)	Internal Configuration	Yes
RTR-01	192.168.1.1	Home Network Router	Network Routing	No (Excluded)

3. STRIDE Threat Model

The following threat model evaluates the authorized in-scope assets (specifically the Web Application SRV-01) using the STRIDE methodology to identify potential abuse cases and rank mitigations.

Threat Category	Abuse Case (Scenario)	Asset Affected	Risk Level	Proposed Mitigation
Spoofing	Attacker bypasses authentication by forging a session token or stealing an active cookie over HTTP.	SRV-01 (Auth Module)	High	Implement strict session management, secure/HttpOnly flags on cookies, and enforce HTTPS.
Tampering	Attacker alters the price of an item in the shopping cart using an intercepting proxy (Burp Suite).	SRV-01 (API Endpoints)	High	Implement server-side validation for all incoming data; do not trust client-side values.
Repudiation	A user deletes critical configuration files and denies the action due to a lack of logging.	SRV-02 (Database)	Medium	Implement centralized logging and audit trails for all sensitive transactions and admin actions.
Information Disclosure	Verbose error messages reveal database structure via SQL injection flaws.	SRV-01 (Database Queries)	Critical	Use parameterized queries (Prepared Statements) and generic error handling.
Denial of Service	Attacker floods the login endpoint with requests, causing the service to crash.	SRV-01 (Web Server)	Low (Out of scope)	Implement rate limiting and CAPTCHA for authentication endpoints.
Elevation of Privilege	Attacker exploits Insecure Direct Object Reference (IDOR) to access admin accounts.	SRV-01 (Access Control)	High	Implement object-level authorization checks before granting access to resources.

4. Data-Flow Diagram (Summary)

Trust Boundaries: The primary trust boundary exists between the External User (Untrusted) and the Web Application Interface (SRV-01). A secondary boundary exists between SRV-01 and the internal Database (SRV-02).

Data Flow: User -> [HTTP/S] -> Web Application -> [Local Socket/TCP] -> Database. Threat actors primarily operate outside the first trust boundary, attempting to inject payloads through the HTTP/S data flow.